Introduction to Network Security: Cryptography, Firewalls, and VPNs

Introduction to Network Security

- Network security refers to the policies, technologies, protocols, and practices used to protect computer networks and the data transmitted through them from unauthorized access, misuse, modification, disclosure, and disruption.
- Modern computer networks connect computers, servers, mobile devices, cloud platforms, and IoT devices. These connections make communication easier but also expose systems to threats such as eavesdropping, malware, identity theft, and denial-of-service attacks.
- Network security aims to ensure that data is transmitted securely and that network resources remain available to authorized users.

Objectives of network security

Confidentiality

Prevents unauthorized disclosure of information.

Integrity

Protects information against unauthorized modification.

Availability

Keeps systems and services accessible to authorized users.

Authentication

Verifies the identity of a user, device, or communicating party.

Additional security properties

- **Authorization:** Determines which resources an authenticated entity can access.
- **Non-repudiation:** Provides evidence that can help prevent a party from falsely denying an action or communication.
- **Accountability:** Records actions so they can be traced to responsible accounts or systems.

Common network security threats

Threat	Description	Example
Eavesdropping	Unauthorized observation of network traffic	Reading unencrypted messages over public Wi-Fi
Spoofing	Falsifying an identity or network address	A fake website impersonating a bank
Malware	Malicious software that damages, monitors, or controls systems	Ransomware spreading across a network
Man-in-the-middle (MITM)	An attacker intercepts or relays communication between parties	Intercepting an insecure connection
Denial of Service (DoS)	Making a service unavailable by exhausting resources	Flooding a server with requests
Phishing	Deceiving users into disclosing credentials or other information	A fraudulent login email
Data modification	Unauthorized alteration of transmitted information	Changing a transaction amount

Major network security mechanisms

Three important technologies are:

- Cryptography: Protects information through encryption, hashing, and cryptographic authentication.
- Firewalls: Control network traffic according to security rules.
- Virtual Private Networks (VPNs): Create protected communication channels over an untrusted network.

These technologies serve different purposes and are often deployed together.

Cryptography

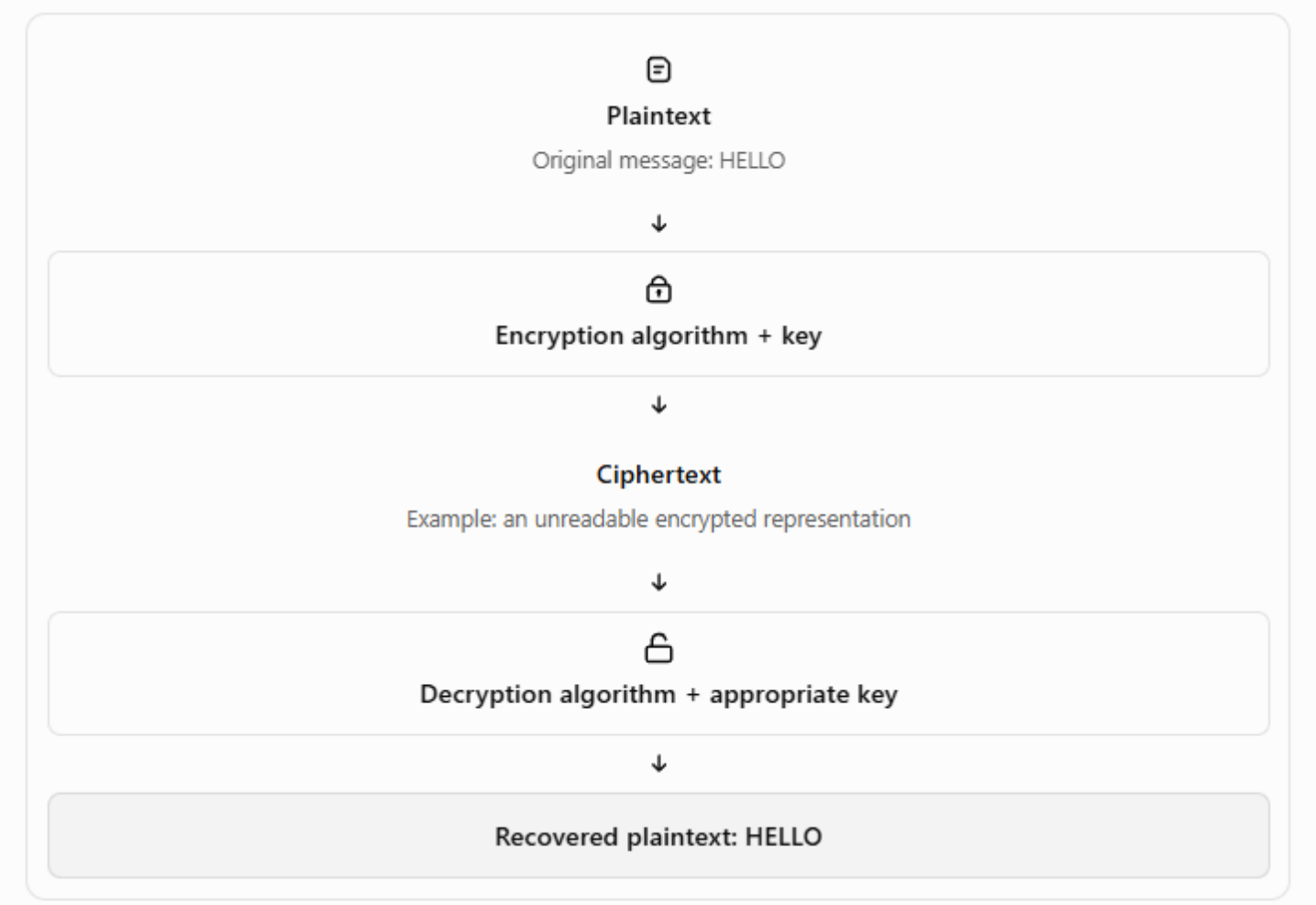
Definition

- Cryptography is the science of securing information by using mathematical techniques and algorithms. It allows communicating parties to protect data even when the communication channel may be observed or attacked by unauthorized parties.
- Cryptography is used in secure websites, online banking, messaging applications, digital signatures, password storage systems, and VPNs.
- The main goals of cryptography include confidentiality, integrity, authentication, and support for non-repudiation.

Basic terminology

Term	Meaning
Plaintext	Original readable information
Ciphertext	Transformed information that is not directly readable without the appropriate decryption capability
Encryption	Process of converting plaintext into ciphertext
Decryption	Process of recovering plaintext from ciphertext
Cipher	Algorithm used to encrypt and decrypt data
Key	Value used by a cryptographic algorithm to control encryption, decryption, or another cryptographic operation
Cryptanalysis	Study of methods for analysing or breaking cryptographic protections
Cryptology	The broader study of cryptography and cryptanalysis

Basic cryptographic process



Types of cryptography

Cryptographic systems are commonly classified into symmetric-key cryptography, asymmetric-key cryptography, and cryptographic hash functions.

1. Symmetric-key cryptography
2. Asymmetric-key cryptography

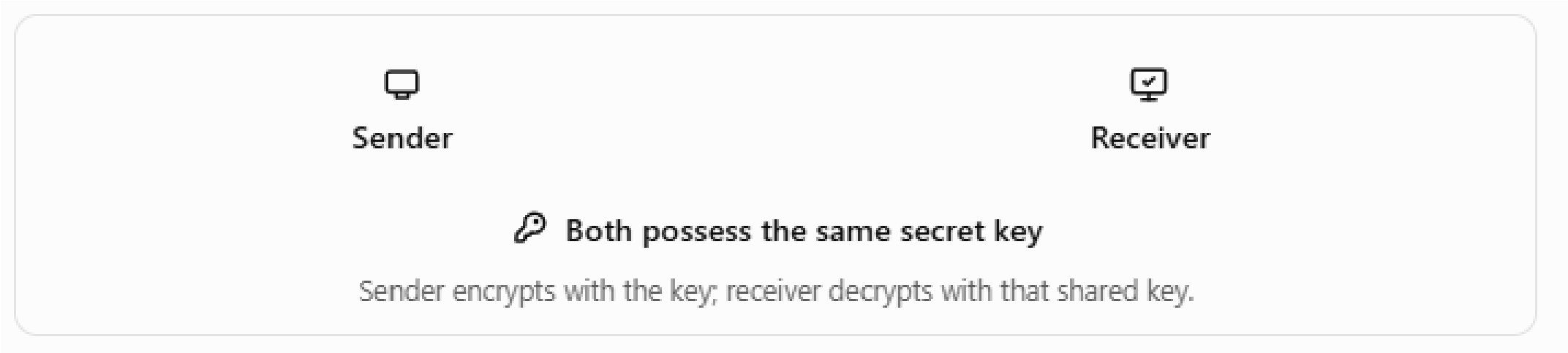
Symmetric-key cryptography

- Symmetric-key cryptography uses the same secret key, or closely related secret key material, for encryption and decryption.
- The communicating parties must securely establish and protect the shared secret key.

Working:

1. The sender and receiver obtain a shared secret key.
2. The sender encrypts the plaintext using a symmetric algorithm.
3. The encrypted message is transmitted.
4. The receiver decrypts it using the shared key.

Symmetric-key cryptography



Examples:

- AES (Advanced Encryption Standard)
- ChaCha20
- DES (Data Encryption Standard; now considered insecure for modern protection because its key is too short)
- 3DES (legacy algorithm, now deprecated for most modern uses)

Asymmetric-key cryptography

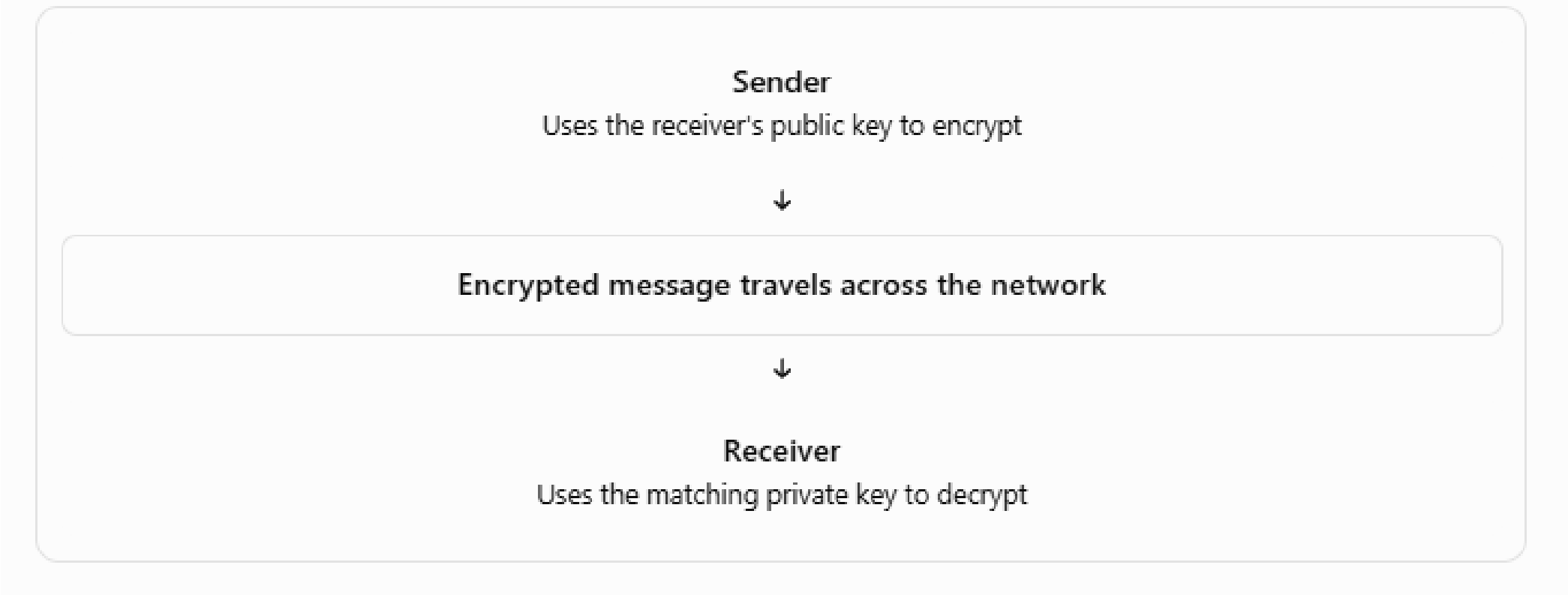
Asymmetric-key cryptography, also called public-key cryptography, uses a mathematically related pair of keys:

- Public key: Can be shared with others.
- Private key: Must be kept secret by its owner.

Examples:

- RSA
- Elliptic Curve Cryptography (ECC)
- Elliptic Curve Diffie–Hellman (ECDH), for key agreement
- Diffie–Hellman key exchange, a foundational method for establishing shared secrets

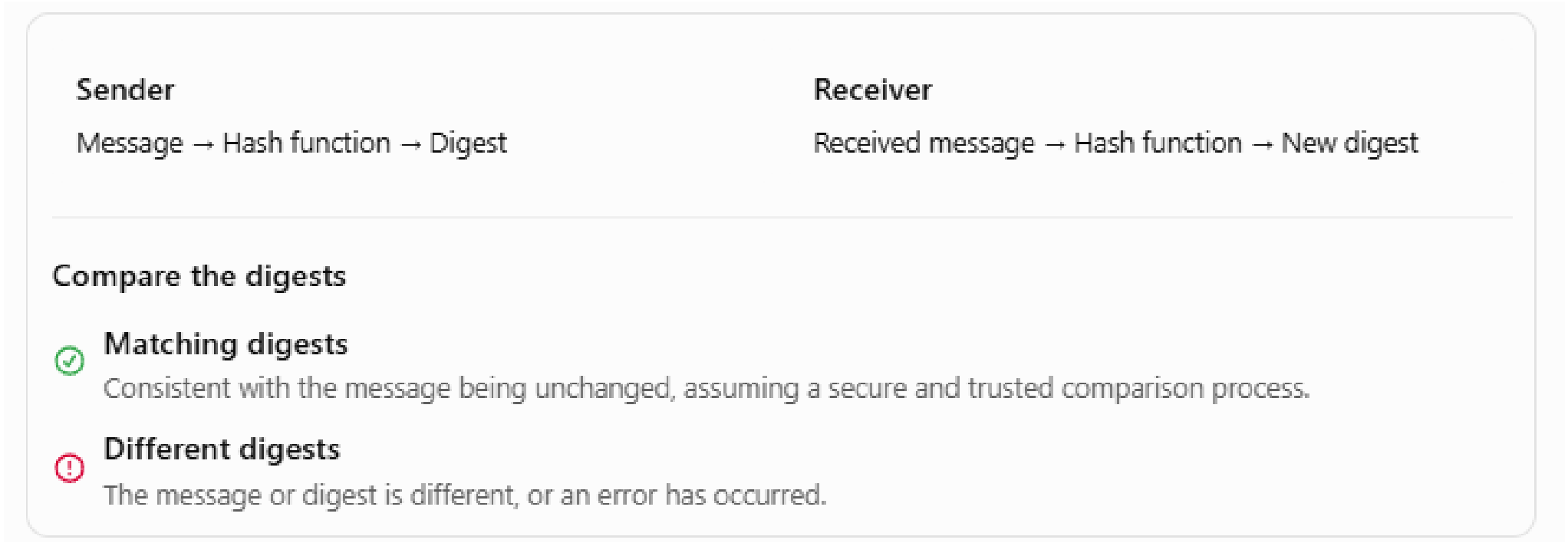
Asymmetric-key cryptography



Hash functions and message integrity

- A cryptographic hash function transforms input data of arbitrary length into a fixed-length output called a hash value or message digest.
- Unlike encryption, hashing is designed to be a one-way operation. A secure hash function should make it computationally infeasible to reconstruct the original message from its digest.
- Examples: SHA-256 and SHA-3. MD5 and SHA-1 are considered unsuitable for applications requiring modern collision resistance.

Hash functions and message integrity



Hash functions and message integrity

Working

1. The sender applies a hash function to the message.
2. A fixed-length digest is generated.
3. The receiver calculates the digest of the received message using the same hash function.
4. The receiver compares the locally calculated digest with the digest received through a trusted mechanism.
5. If they differ, the message or digest has changed, or a transmission or processing error has occurred.

Digital signatures

A digital signature is a cryptographic mechanism used to verify the authenticity and integrity of a digital message or document.

Working:

1. The sender calculates a digest of the message.
2. The sender signs the digest using a suitable digital-signature algorithm and the sender's private key.
3. The message and signature are sent to the receiver.
4. The receiver uses the sender's public key to verify the signature.
5. If verification succeeds, the receiver gains evidence that the signature corresponds to the message and the claimed signing key.

Digital signatures

- Digital signatures support integrity, origin authentication, and evidence useful for non-repudiation.
- Their strength depends on secure key management, correct verification, and reliable identification of the key owner.

Example: A software developer digitally signs a software release so users can verify that it came from the expected publisher and has not been altered since signing.

Firewalls

Definition

- A firewall is a hardware device, software application, or combination of both that monitors and controls incoming and outgoing network traffic according to a defined security policy.
- It establishes a controlled boundary between networks or security zones—for example, between an organization's internal network and the public Internet.
- A firewall typically permits, rejects, or drops traffic based on rules involving addresses, protocols, ports, connection state, or application-level information.
- Firewalls are an important part of network security, but they do not replace endpoint protection, authentication, patching, or other security controls

Why are firewalls required?

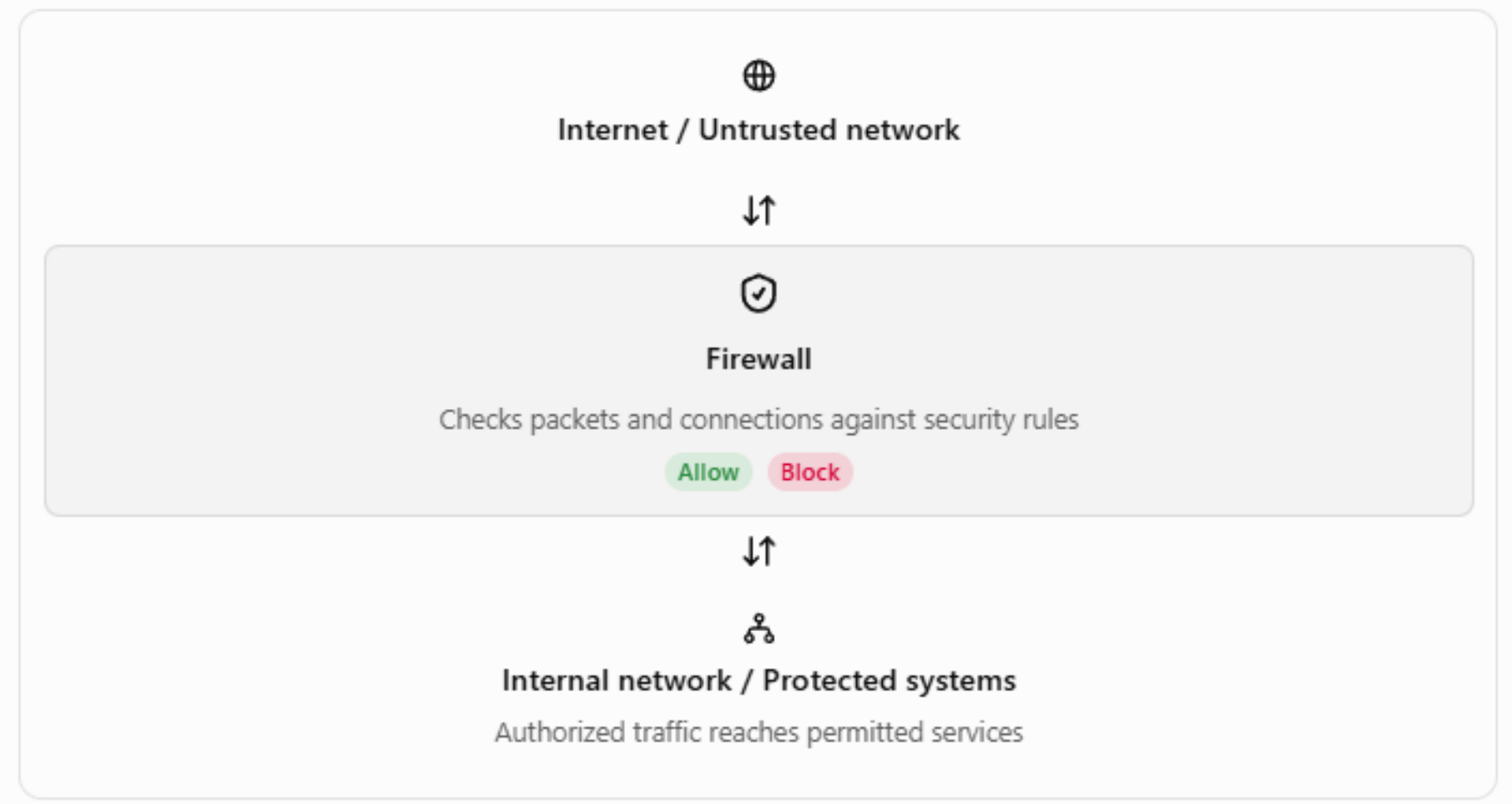
Organizations use firewalls to:

- Prevent unauthorized connections to internal systems.
- Restrict access to network services.
- Control traffic entering and leaving the organization.
- Segment networks and limit movement between security zones.
- Record or monitor selected network events.
- Reduce exposure to unwanted network traffic.

A firewall administrator defines rules specifying which connections are permitted and which must be blocked.

A secure configuration generally denies traffic that is not explicitly permitted by the applicable policy, while allowing necessary services.

Basic firewall architecture



Types of firewalls

Packet-filtering firewall

A packet-filtering firewall examines individual packets and applies rules based on fields such as:

- Source IP address.
- Destination IP address.
- Source and destination port numbers.
- Transport protocol, such as TCP or UDP.
- Direction of traffic.

It makes decisions using packet-header information without necessarily examining application content.

Types of firewalls

Example: A rule allows TCP traffic to a public web server on port 443 but blocks unsolicited external connections to an internal computer.

Advantages

- Simple and efficient.
- Low processing overhead.
- Useful for basic traffic filtering.

Disadvantages

- Basic stateless filtering does not track the context of a connection.
- Limited ability to interpret application-layer behaviour.
- Incorrectly configured rules may expose internal services.

Types of firewalls

Stateful inspection firewall

- A stateful firewall tracks the state of network connections. It maintains a connection table and evaluates packets in the context of existing sessions.
- For example, when an internal computer establishes an authorized TCP connection to a website, the firewall can allow the corresponding return traffic as part of that connection, according to its state and rules.

Types of firewalls

Advantages

- More context-aware than basic stateless filtering.
- Can distinguish expected return traffic from unrelated packets.
- Useful for controlling connection-oriented traffic.

Disadvantages

- Requires memory and processing to track connection state.
- May be affected by resource exhaustion or implementation vulnerabilities.
- Does not automatically detect all malicious application activity.

Types of firewalls

Application-level gateway (proxy firewall)

- A proxy firewall acts as an intermediary between a client and a destination service. It can terminate one connection and create another, examining application-level requests before forwarding them.
- For example, an organization's web proxy may enforce rules about which websites employees can access.

Types of firewalls

Advantages

- Can inspect application-specific requests.
- Can enforce detailed application policies.
- Can help hide internal addressing and separate internal clients from external services.

Disadvantages

- May introduce latency.
- Requires suitable proxy support for the applications being controlled.
- Encrypted traffic requires appropriate handling if deeper inspection is needed.

What firewalls cannot do

A firewall is not a complete security solution. It may not prevent:

- Phishing attacks in which users voluntarily disclose credentials.
- Malware introduced through permitted channels.
- Attacks against vulnerable applications exposed through allowed ports.
- Insider misuse of authorized access.
- Attacks through misconfigured rules or compromised devices.
- All malicious activity hidden within encrypted traffic.

A layered security approach combines firewalls with endpoint security, secure authentication, software updates, monitoring, backups, and user awareness.

Virtual Private Networks (VPNs)

Definition

- A Virtual Private Network (VPN) is a technology that establishes a protected logical connection across an existing network, such as the public Internet.
- A VPN can connect a remote user to an organization's private network or securely connect two geographically separated networks. Depending on the VPN technology, it can provide encryption, authentication, integrity protection, and tunnelling.
- A VPN does not necessarily provide all these services by itself; the specific protocol and configuration determine the protection offered.

Why are VPNs required?

Organizations may have offices, employees, servers, and resources distributed across different locations. Using dedicated private communication links between every location can be expensive.

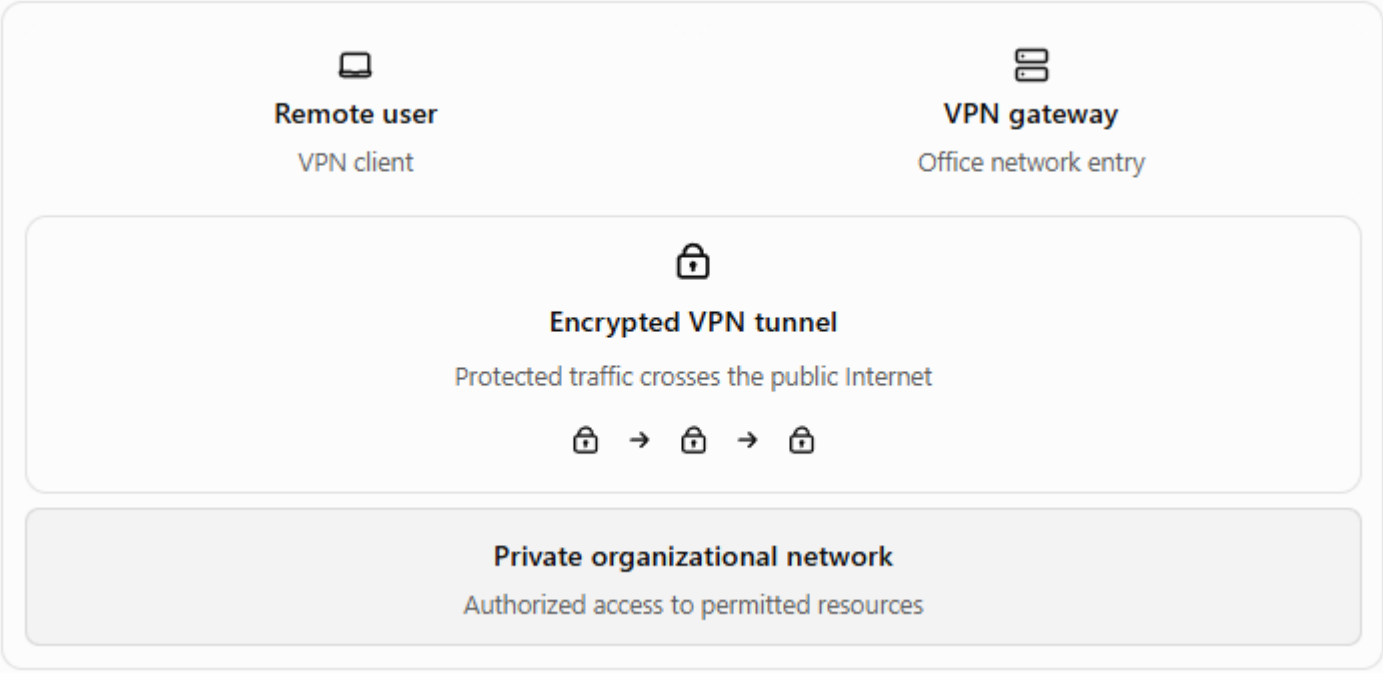
VPNs use existing network infrastructure to establish protected communications.

Common applications include:

- Remote access to office applications and files.
- Secure connections between branch offices.
- Access to internal academic or corporate systems while travelling.
- Protection of network traffic over untrusted networks.
- Secure connectivity between cloud environments and organizational networks.

How a VPN works

- A VPN commonly uses tunnelling to carry traffic through an existing network. Where encryption is supported and correctly configured, the original traffic is protected before being transmitted through the tunnel.



How a VPN works

Step-by-step operation

1. The user starts a VPN client or connects through a supported VPN device.
2. The client and VPN gateway establish a connection using the selected VPN protocol.
3. The parties authenticate as required by the configuration.
4. Cryptographic keys and security parameters are established.
5. The VPN encapsulates traffic into tunnel packets and applies encryption and integrity protection when supported.
6. The protected traffic crosses the public network.
7. The VPN gateway verifies and decapsulates the traffic, then forwards authorized traffic toward the destination.
8. Return traffic travels through the VPN according to the configured routing and security policies.

Important: *A VPN does not make every destination or application automatically secure. Access controls, endpoint security, DNS configuration, routing, and the VPN provider or organization's policies still matter.*

Types of VPNs

Remote-access VPN

- A remote-access VPN allows an individual user or device to connect securely to an organization's private network from a different location.
- **Example:** A faculty member working from home connects to the college VPN to access an internal academic server.

Characteristics:

- Connects an individual device to a private network.
- Commonly uses client software or an operating-system VPN client.
- Requires user or device authentication.
- Can restrict access according to the user's role.

Types of VPNs

Site-to-site VPN

A site-to-site VPN connects two or more networks through VPN gateways.

It is commonly used to connect branch offices to headquarters.

Example: A college's main campus and a remote campus securely exchange data over the Internet.

Two common configurations are:

- Intranet VPN: Connects sites belonging to the same organization.
- Extranet VPN: Connects an organization to an authorized external organization, such as a business partner.

Types of VPNs

Host-to-host VPN

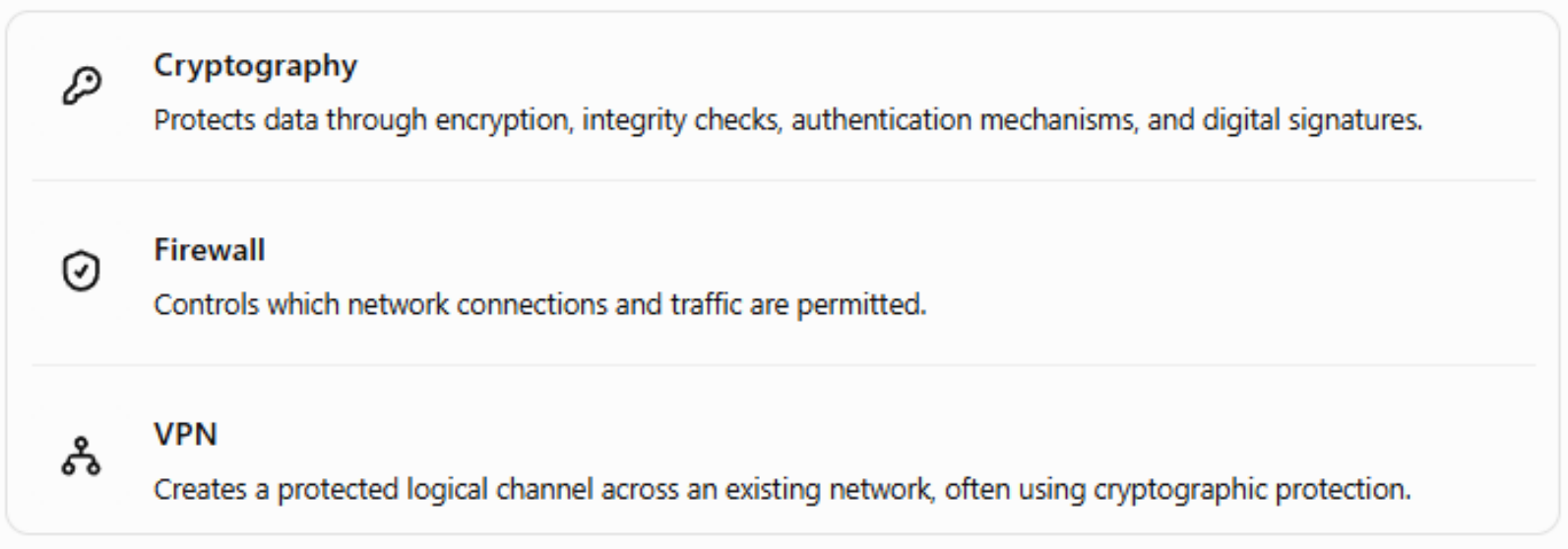
- A host-to-host VPN establishes a protected connection between two individual computers or servers.
- It can be useful when two particular systems need a protected channel without connecting entire networks.

Advantages of VPNs

- Provides protected communication over untrusted networks when properly configured.
- Supports secure access to private organizational resources.
- Can reduce the cost of connecting geographically separated locations.
- Helps protect sensitive traffic from network eavesdropping.
- Supports centralized access policies and authentication.

How Cryptography, Firewalls, and VPNs Work Together

These three technologies address complementary aspects of network security.



How Cryptography, Firewalls, and VPNs Work Together

Real-world example: College network

Suppose a faculty member needs to access an internal college server from home.

1. The faculty member authenticates to the college's remote-access VPN.
2. The VPN uses cryptographic protocols to establish a protected tunnel.
3. The college firewall checks whether the user and connection are permitted to access the internal server.
4. The server applies its own authentication and authorization rules.
5. Network monitoring records relevant security events.

In this scenario, the VPN protects the communication channel, cryptography supports confidentiality and integrity, and the firewall restricts network access. All three contribute to security, but none replaces the others.

Security Protocols: SSL/TLS and IPsec

Introduction to Security Protocols

- A security protocol is a set of rules that defines how communicating systems establish trust, authenticate parties, protect information, and exchange data securely over a network.
- When information travels across the Internet, an attacker may attempt to intercept, modify, replay, or impersonate network traffic. Security protocols use cryptographic algorithms and communication procedures to defend against these threats.

Security Protocols: SSL/TLS and IPsec

Two important security technologies are:

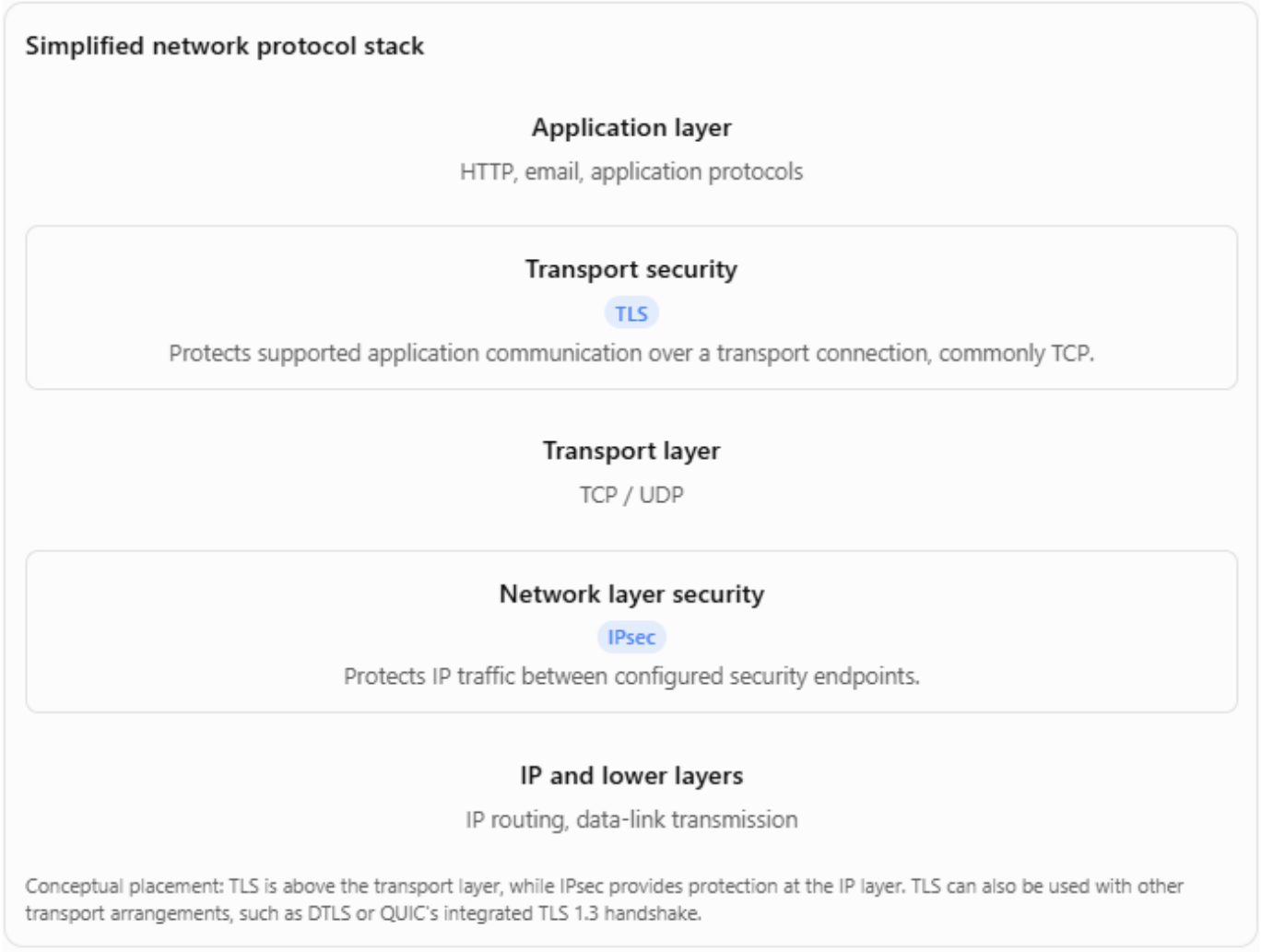
- SSL/TLS: Protects communication between applications, such as a web browser and a web server.
- IPsec: Provides security at the Internet Protocol (IP) layer and is widely used to build VPNs.

Although both use cryptography, they operate at different layers and are designed for different communication needs.

Objectives of security protocols

Objective	Description
Confidentiality	Prevents unauthorized parties from reading protected data.
Integrity	Helps detect unauthorized modification of data.
Authentication	Verifies the identity of a communicating party or the origin of data.
Anti-replay protection	Helps prevent attackers from capturing and replaying previously transmitted protected packets or messages.
Key establishment	Enables communicating parties to establish cryptographic keys securely.

Where SSL/TLS and IPsec operate



SSL (Secure Sockets Layer)

Secure Sockets Layer (SSL) is a cryptographic protocol originally developed to secure communication between applications over a network. It became widely known through its use in securing web traffic.

SSL was designed to provide:

- Confidentiality through encryption.
- Message integrity.
- Authentication, especially server authentication using certificates.

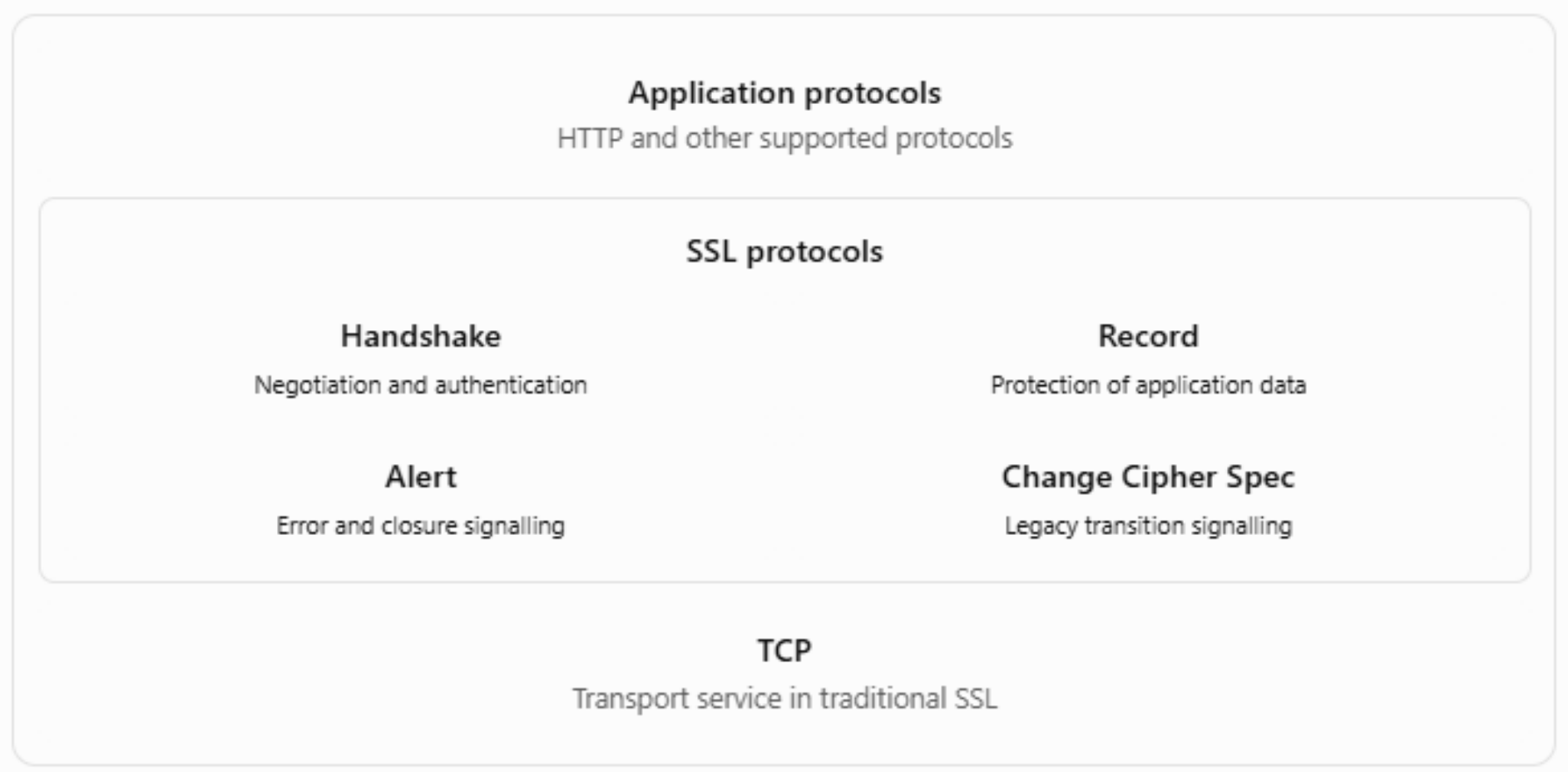
However, SSL versions have serious known security weaknesses and are obsolete. SSL 2.0 and SSL 3.0 must not be used in modern secure deployments.

Important: *SSL is now mainly a historical term. Modern secure web communication uses TLS, the successor to SSL.*

Why was SSL introduced?

- In early web communication, HTTP traffic was generally transmitted without cryptographic protection. An attacker positioned along the communication path could potentially read or modify the information.
- For example, when a user submitted login credentials through an unprotected HTTP connection, those credentials could be exposed to network interception.
- SSL was introduced to create a secure channel between a client and a server, allowing data to be encrypted and authenticated.

SSL architecture



Components of SSL

1. Handshake Protocol
   - The Handshake Protocol allowed the client and server to negotiate cryptographic parameters, authenticate the server, and establish shared secret key material.
2. Record Protocol
   - The Record Protocol handled application data and certain SSL control messages. It provided confidentiality and integrity according to the negotiated cipher suite.
3. Alert Protocol
   - The Alert Protocol communicated errors and connection-closure information.
4. Change Cipher Spec Protocol
   - In legacy SSL and early TLS designs, this message signalled a change to the negotiated protection state. It has a much more limited role in modern TLS.

TLS (Transport Layer Security)

Transport Layer Security (TLS) is a cryptographic protocol that provides secure communication between applications over a network. It evolved from SSL and is standardized by the Internet Engineering Task Force (IETF).

TLS is widely used in HTTPS, secure APIs, email transport protection, and many other application protocols.

TLS aims to provide:

- Confidentiality: Application data is encrypted.
- Integrity: Unauthorized modification of protected records can be detected.
- Authentication: Certificates or other supported credentials can verify the communicating parties.
- Secure key establishment: The parties derive session keys for protecting data.

TLS Architecture and Working

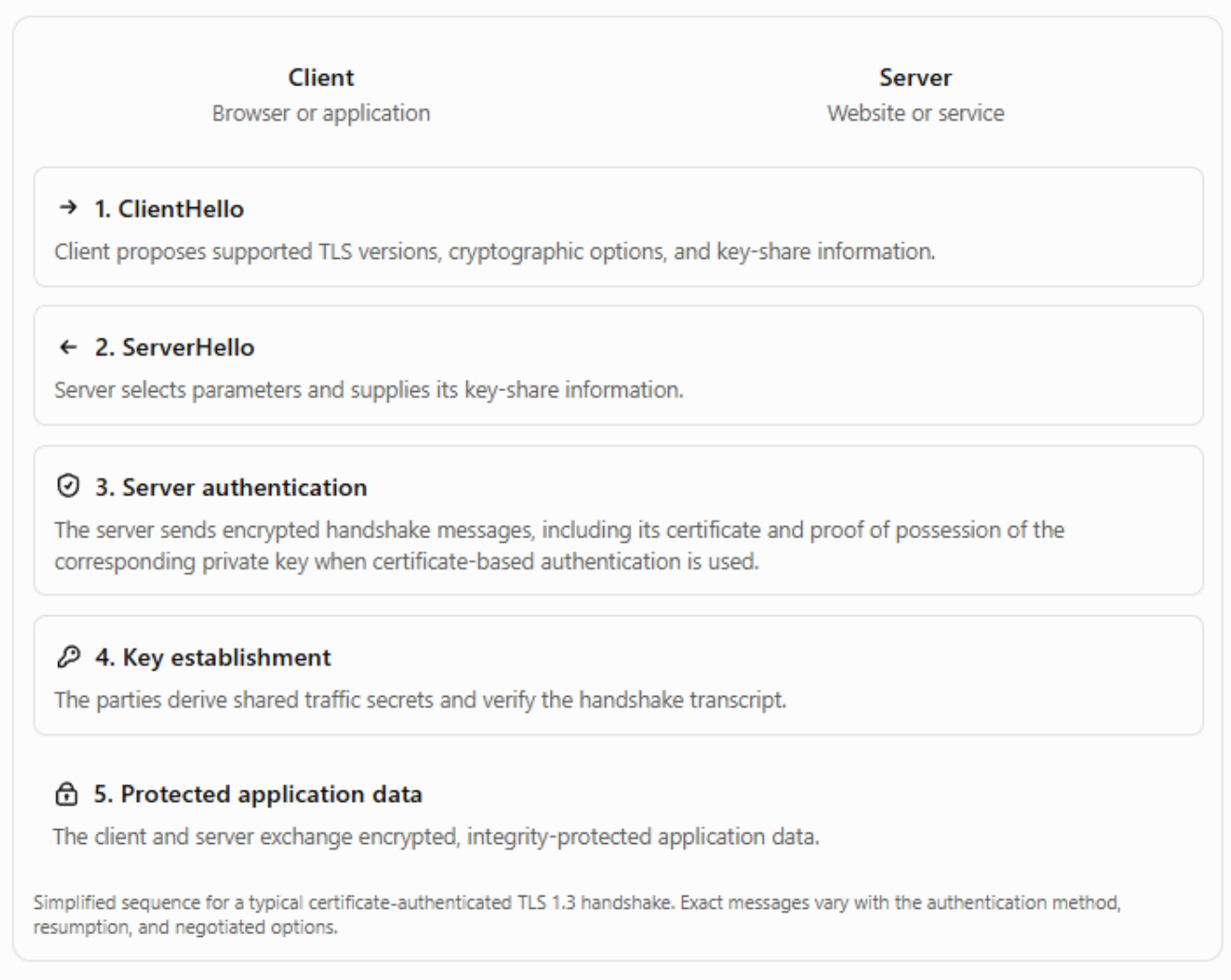
- TLS connection architecture
  - TLS usually operates between an application protocol and a reliable transport protocol such as TCP. HTTPS uses HTTP protected by TLS.
  - For example, when a user visits https://example.com, the browser establishes a TLS connection with the server before exchanging protected HTTP application data.
  - The main TLS components in TLS 1.2 include the Handshake Protocol, Record Protocol, Alert Protocol, and Change Cipher Spec mechanism.
  - TLS 1.3 simplifies and changes several aspects of the earlier architecture, so legacy SSL/TLS diagrams should not be interpreted as applying unchanged to TLS 1.3.

TLS handshake process

The TLS handshake establishes the security parameters for communication. Depending on the TLS version and configuration, it negotiates cryptographic algorithms, authenticates the server, establishes shared key material, and may authenticate the client.

- **Simplified TLS 1.3 handshake**

Simplified TLS 1.3 handshake



Simplified TLS 1.3 handshake

Step 1: ClientHello

- The client sends a ClientHello message containing supported TLS versions, cryptographic capabilities, and key-share information. It may also identify the intended server name through the Server Name Indication (SNI) extension.

Step 2: ServerHello

- The server selects compatible parameters and responds with its ServerHello message and key-share information.

Simplified TLS 1.3 handshake

Step 3: Key derivation

- The client and server use the negotiated key-establishment mechanism, commonly ephemeral Diffie–Hellman, to derive shared secret material. In TLS 1.3, the key schedule derives separate traffic secrets for different communication directions and stages.

Step 4: Server authentication

- The server typically sends a digital certificate containing its public key and identity information, followed by proof that it possesses the corresponding private key. The client validates the certificate chain, hostname, validity, and other applicable requirements.

Simplified TLS 1.3 handshake

Step 5: Finished messages

- The communicating parties verify the handshake transcript using cryptographic authentication. This helps detect tampering with the handshake messages.

Step 6: Application data transfer

- After the handshake reaches the required state, the client and server exchange application data protected using the derived traffic keys.

IPsec (Internet Protocol Security)

IPsec is a suite of protocols that provides security services at the IP layer. It can protect IP packets travelling between two hosts, between two security gateways, or between a host and a security gateway.

IPsec is widely used to implement VPNs, especially site-to-site VPNs connecting organizational networks across the Internet.

IPsec can provide:

- Confidentiality.
- Data integrity.
- Data-origin authentication.
- Anti-replay protection.
- Access control through security policies.

The exact services depend on the IPsec protocol, mode, algorithms, and configuration.

Why is IPsec required?

- IP is primarily responsible for addressing and routing packets. Ordinary IP traffic does not inherently encrypt its contents or authenticate its source.
- For example, a company may need to exchange internal database traffic between two offices over the public Internet. Without an appropriate security mechanism, sensitive information could be exposed or altered along the path.
- IPsec can protect IP traffic between configured endpoints without requiring every application to implement its own encryption.

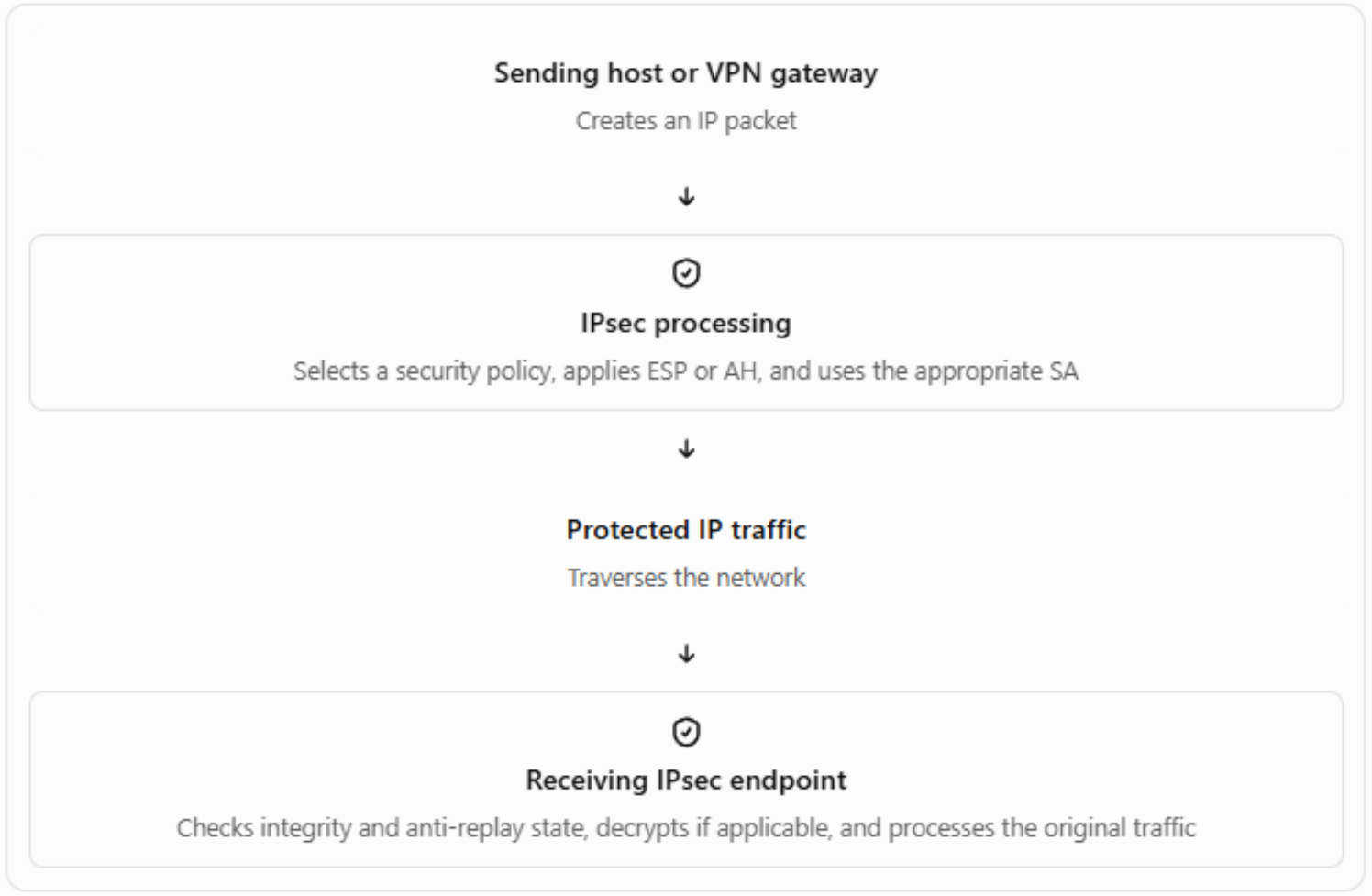
IPsec architecture

The main IPsec components are:

- Authentication Header (AH): Provides integrity, data-origin authentication, and anti-replay support where configured, but not confidentiality.
- Encapsulating Security Payload (ESP): Can provide confidentiality, integrity, data-origin authentication, and anti-replay protection.
- Internet Key Exchange (IKE): Negotiates security parameters and establishes keys used by IPsec.
- Security Association (SA): Defines the security parameters used to protect traffic in one direction.

ESP is the commonly used protocol for modern IPsec VPN deployments.

Basic IPsec operation



Basic IPsec operation

Step-by-step explanation

1. The sender's IPsec policy determines whether the traffic should be protected.
2. The appropriate Security Association (SA) supplies the security parameters, algorithms, and keys.
3. IPsec applies ESP or AH according to the configuration.
4. The protected packet is transmitted across the network.
5. The receiving endpoint identifies the applicable SA.
6. It checks packet integrity and anti-replay information, and decrypts the packet if ESP confidentiality is enabled.
7. The receiving endpoint forwards the recovered packet or delivers its contents to the appropriate processing layer.